

テーマ：Cybersecurity Web_Page_Best Practices

Internship student：Davaakhuu Undarmaa（v25y0009）

Internship の企業: 公益財団法人 九州先端科学技術研究所
(Institute of Systems, Information Technologies and Nanotechnologies (ISIT))

1.Introduction

本インターンシップは、(ISIT) において、約1か月間実施したものである。本機関をインターンシップ先として選択した理由は、オープンデータを活用した研究・開発を行っている点に強い関心を持ったためである。また、日本の研究機関における実務経験を通じて、技術的な基礎知識や実践的なスキルだけでなく、組織文化や職場環境についても学ぶことを目的として、本インターンシップに参加した。インターンシップ期間中、ISIT が運営する複数の Web ページに触れる機会があり、これらの Web システムが多くの利用者に情報を提供する重要な役割を担っていることを理解した。一方で、私自身がこれまで情報セキュリティ分野に関心を持ち、特に web セキュリティについて基礎的な知識を学んできたことから、研究テーマとして

「Cybersecurity Web Page Best Practices」を選択した。

本レポートでは、インターンシップを通じて学んだ Web セキュリティに関する知識を整理し、Web ページを安全に運用するためのプラクティスについて考察する。

2.Overview of Web Security Threats

近年、Web アプリケーションやインターネットに接続されたシステムを狙うサイバー攻撃は急速に増加している。具体的な統計からもその深刻さが確認されている。

まず、2024 年に観測された Web アプリケーションへの攻撃総数は 12 億件を超え、1 日平均約 330 万回に達したと報告されている。前年同期比では 154% の増加であり、攻撃の頻度と規模が拡大していることがわかる。さらに 2025 年第 1 四半期の統計では、3 か月間で約 3 億 6,700 万件のサイバー攻撃が検知され、1 日に最大約 692 万件、1 秒あたり約 80 回もの攻撃が発生したとされている。前年同期と比べても約 3 倍の増加傾向が観測される。攻撃の種類としては、ボットネットによる大量アクセスや DDoS、脆弱性スキャン、SQL インジェクションやクロスサイトスクリプティングなどの Web 攻撃が依然として多い。また、ランサムウェア攻撃は 2025 年後半にかけて前年比約 60% 増加しており、生成 AI を悪用した情報漏えいリスクも指摘されている。このように、Web セキュリティ脅威は単なる増加傾向にとどまらず、攻撃の精巧化と自動化が進んでいる点が特徴であり、適切な防御対策の継続的な実施が強く求められている。

3. インターンシップで行った3つの活動

私はインターンシップ期間中、主に以下の3つの活動を行いました。まず、ネットワークセキュリティ分析ツールの作成に取り組みました。この活動では、ログ解析を通じてネットワーク通信の挙動を確認し、不審なアクセスや異常の検知について学びました。次に、テスト用の Web サイトを作成し、Web アプリケーションに対する攻撃からの基本的な防御方法について学習しました。実際に Web サイトを構築することで、セキュリティ対策を実装する重要性を理解しました。さらに、DVWA (Damn Vulnerable Web Application) という Web 攻撃のパターンを学習できるテスト用プログラムを使用しました。DVWA を用いてさまざまな攻撃パターンを実際に実行しながら、それぞれの攻撃手法の仕組みや影響、対策の基本について理解を深めました。

4. My Chosen Topic

- Traffic Eye_Log Analyzer
- Web ページ上でのアクセス制御方法に関する調査

インターンシップ期間中、実際に稼働している Web サーバーのアクセスログ分析に取り組みました。はじめに、1日分のサーバーログを PowerShell を用いて手作業で分析しましたが、ログの量が非常に多く、HTTP ステータスコード (404、400、499 など) や不審なリクエストを一つ一つ確認する作業には、長時間を要しました。

```
geoserver/web/ HTTP/1.1" 404 132717  
6.71 Safari/537.36 SE 2.X MetaSr 1.0  
sit.or.jp_20250805.log:2:Aug 5 00:16  
.git/config HTTP/1.1" 404 132717 "-"  
afari/537.36"  
sit.or.jp_20250805.log:4:Aug 5 00:51  
version HTTP/1.1" 499 0 "-" "Mozilla/
```

```
jp_20250805.log:4:Aug 5  
HTTP/1.1" 499 0 "-" "Mo  
4.1 Mobile/15E148 Safari/  
jp_20250805.log:12:Aug
```

```
og:743:Aug 5 12:52:55 m089.is  
/1.1" 400 255 "-" "Mozilla/5.0  
og:841:Aug 5 13:31:01 m089.is  
pbf HTTP/1.1" 499 0 "https://  
5_7) AppleWebKit/537.36 (KHTML  
og:842:Aug 5 13:31:01 m089.is  
pbf HTTP/1.1" 499 0 "https://
```

```
hp HTTP/1.0" 404 153 "-" "Mozilla/5.0  
Log:3524:Aug 5 20:49:03 m089.isit.or  
443 HTTP/1.1" 400 157 "-" "  
Log:3528:Aug 5 20:59:24 m089.isit.or  
B%7B%20data.uploadedToLink HTTP/1.1"  
5.0 (compatible; Thinkbot/0.5.8; +In
```

この経験を通じて、ログ分析を効率化し、継続的に不正アクセスや異常なトラフィックを検知するためには、自動化された仕組みが不可欠ではないかと考えるようになりました。特に、

- 不正アクセスの兆候をログからどのように検知できるか
- アクセス制御によって被害をどのように低減できるか

という点に着目し、実践的な視点から Web セキュリティへの理解を深めることを目的としました。

5. ネットワークセキュリティ分析ツールを作成

その名前は「**Traffic Eye_Log analyzer**」です. サーバーログ解析システム

Traffic Eye_Log Analyzer は、ログを自動で解析し、グラフで可視化することで、疑わしい IP や高負荷を迅速に特定し、管理者の作業時間を節約し、セキュリティを向上させます. サーバー管理者の負担軽減とセキュリティ向上を目的とした

主な特徴 1：ログの読み込み・データ処理

- 本システムは、Web サーバーで生成される
- access.log および error.log を読み込み、以下の情報を解析
- IP アドレス
- リクエストタイプ (GET、POST など)
- リクエスト時刻
- HTTP ステータスコード (200、404、500 など)

これにより、アクセスの傾向やエラー発生状況を効率的に把握することが可能となる。

主な特徴 2：統計情報の集計・可視化

解析したログデータを基に、以下の統計情報を算出する。

- 総ユニーク IP アドレス数
- 最大リクエスト数を送信した IP アドレス
- 最もアクセスされた URL
- 日別・時間別・分別のトラフィック量

これらの情報は、横棒グラフ、縦棒グラフ、円グラフ、折れ線グラフ を用いて可視化され、管理者が直感的にアクセス状況を把握できるようにしている。

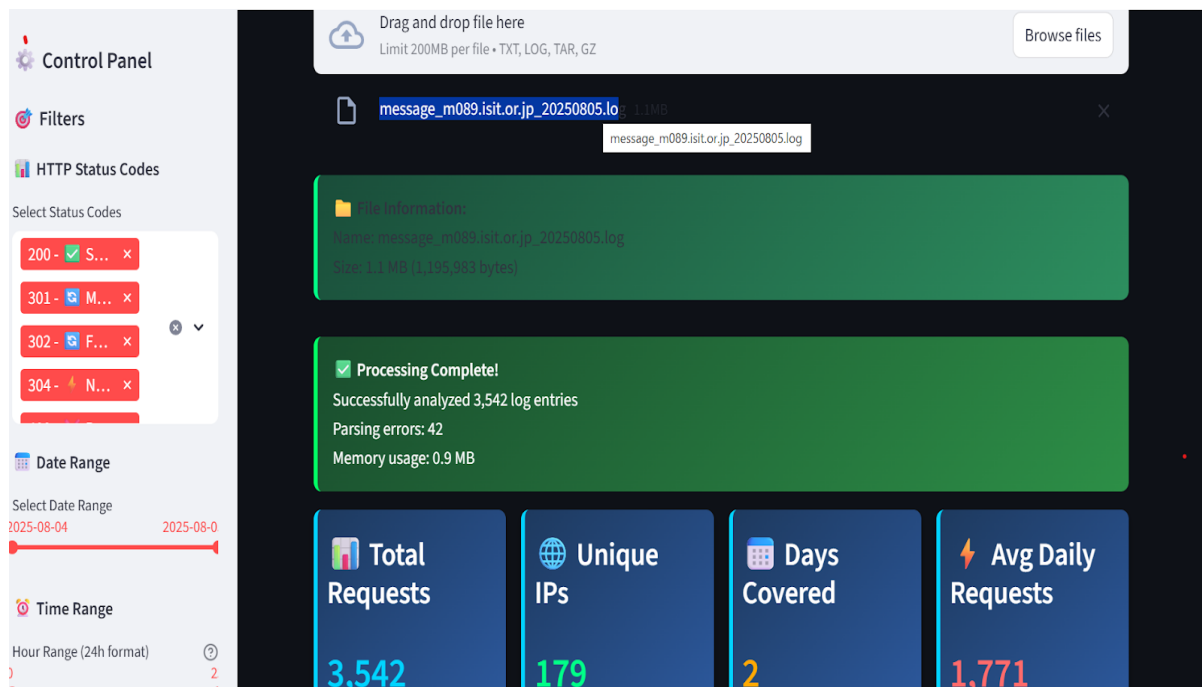
主な特徴 3：セキュリティ分析機能

本システムでは、ログ解析結果を基に以下のような セキュリティ分析 を行う。

- 短時間に繰り返しリクエストを送信する IP アドレスの特定
- 過剰なリクエストを行う IP アドレスに対するブロック提案
- ブルートフォース (Brute Force) 攻撃などの兆候検出

これにより、不正アクセスの早期発見や被害の未然防止を支援する。

これが私が作成した、プログラムの画面いろいろな分析が行えます



目的・分析範囲: 本分析の目的は、特定の日における Web サーバーのアクセスログを詳細に解析し、トラフィックの傾向を把握するとともに、高負荷を与えている IP アドレスや不審なアクセスを特定することにある。

ログデータの出所: (bodic.jp Nginx) message_m089.isit.or.jp_20250805.log) を入力データとして使用した。(ISIT_Log) 「Traffic Eye_Log Analyzer」 によるログ解析結果画面を示している。

本システムは、Web サーバーの access log / error log を入力として受け取り、ログデータを自動的に解析し、アクセス状況やセキュリティ上の特徴を可視化することを目的としたサーバーログ解析システムである。

➤ ログファイルの読み込みと解析結果

画面上部では、対象となるログファイルをドラッグ&ドロップまたはファイル選択によってアップロードすることができる。

ログファイルの読み込み後、システムは自動的に解析処理を実行し、以下の結果が得られた。

- 解析対象ログ件数：3,542 件
- パースエラー数：42 件
- メモリ使用量：約 0.9MB

この結果から、本システムは比較的軽量なリソース消費で、大量のログデータを処理できることが確認できた。

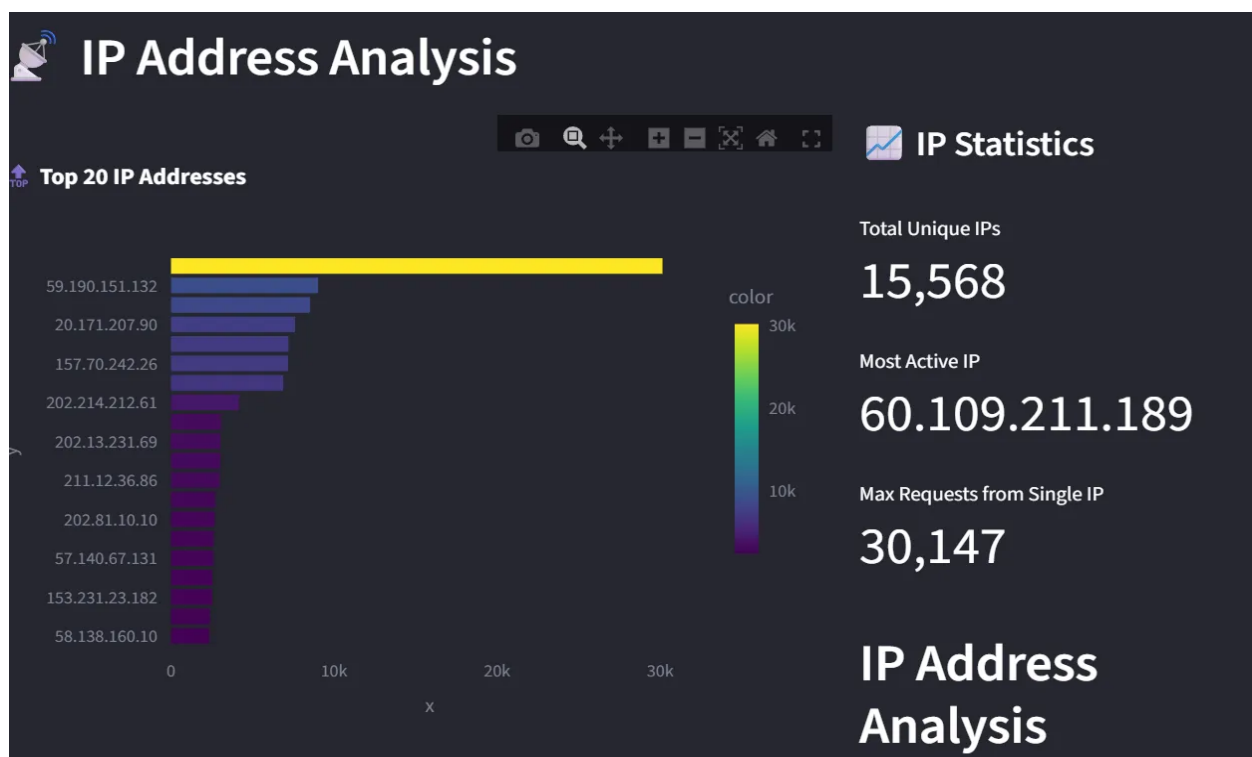
アクセス統計情報の可視化

画面下部には、ログ解析によって得られた主要な統計情報がカード形式で表示されている。

- Total Requests：解析対象期間における総リクエスト数（3,542 件）
- Unique IPs：アクセス元のユニーク IP アドレス数（179 件）
- Days Covered：ログが含む期間（日数）（2 日間）
- Avg Daily Requests：1 日あたりの平均リクエスト数（1,771 件）

これらの情報により、対象 Web サーバーのアクセス規模やトラフィックの傾向を直感的に把握することが可能である。

➤ 1.IP Address Analysis



IP アドレス分析 セクションの主な目的は、IP アドレスの動きを監視・分析し、潜在的なセキュリティリスクを特定することです。このセクションの目的は、単に IP アドレスを一覧化することではなく、その背後にあるユーザー行動、システム負荷、そして潜在的なセキュリティリスクを総合的に評価し、必要に応じて迅速に対応できるようにすることです。

内容	詳細
Top 20 IP アドレス	・ アクセス数が多い上位 20 件の IP アドレスを表示・ カラーバーでアクセス数を表現（緑：多い、青／紫：少ない） ・ 60.109.211.189 が最多アクセス（500 回以上）
総ユニーク IP 数	（異なる IP アドレスの総数） 30,147
最も活発な IP	60.109.211.189 （492 回アクセス）
単一 IP からの最大リクエスト数	15,568 回（ 60.109.211.189 より）
各 IP アドレスの詳細	・ IP ごとのアクセス数・ 全体アクセス数に対する割合（%）
不審な IP の可能性	・ 60.109.211.189 と 59.190.151.132 のアクセス数が非常に多い・ 通常ユーザーではなく、ボットや自動化されたアクセスの可能性・ セキュリティ観点から詳細な確認が必要

■ 最も活動的なアドレスの特定

左側のグラフ：サーバーに最も多くアクセスした、または最も多くリクエストを送信した IP アドレスを一覧表示します。これにより、どのアドレス（または地域、ユーザー）がシステムに最も大きな負荷を与えているかを一目で把握できます。

■ セキュリティリスクの評価

Max Requests from Single IP：単一の IP アドレスからのリクエストの最大数を示します。この数値が異常に高い場合：DDoS または DoS 攻撃：システムを停止させる目的で大量のリクエストを送信している可能性があります。ボットの活動：ウェブサイトの情報を収集（スクレイピング）したり、脆弱性を探す自動ボットの可能性があります。Top 20 IP Addresses:このリストに不審または見覚えのない海外 IP が多く含まれている場合、セキュリティチームは注意を払い、調査を行う必要があります。

1. **60.109.211.189** について詳細な調査を行う

60.109.211.189 was not found in our database

ISP	Japan Nation-wide Network of Softbank Corp.
Usage Type	Mobile ISP
ASN	Unknown
Hostname(s)	softbank060109211189.bbtec.net
Domain Name	bbtec.net
Country	 Japan
City	Saitama, Saitama

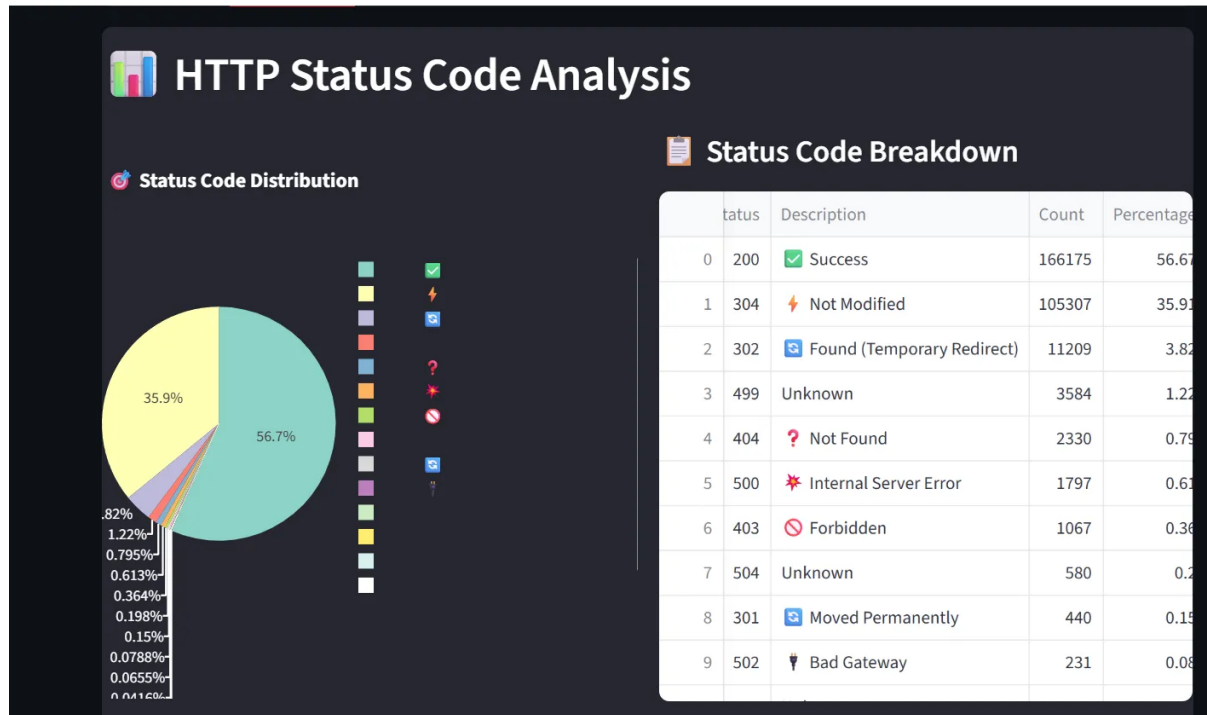
IP Location	 Japan Tokyo Japan Nation-wide Network Of Softbank Corp.
ASN	 AS17676 GIGAINFRA SoftBank Corp., JP (registered Mar 26, 2001)
Resolve Host	softbank060109211189.bbtec.net
Whois Server	whois.apnic.net
IP Address	60.109.211.189

% Abuse contact for '60.96.0.0 - 60.127.255.255' is ' abuse@e.softbank.co.jp '

```
inetnum:        60.96.0.0 - 60.127.255.255
netname:        BBTEC
descr:          Japan Nation-wide Network of Softbank Corp.
country:        JP
org:            ORG-SC4-AP
admin-c:        SA421-AP
tech-c:         SA421-AP
abuse-c:        AS2391-AP
status:         ALLOCATED PORTABLE
remarks:        -----
remarks:        To report network abuse, please contact mnt-irt
remarks:        For troubleshooting, please contact tech-c and admin-c
remarks:        Report invalid contact via www.apnic.net/invalidcontact
remarks:        -----
mnt-by:         APNIC-HM
mnt-lower:      MAINT-JP-BBTECH
mnt-routes:     MAINT-JP-BBTECH
```

➤ 2:HTTP Status Code Analysis

Dep

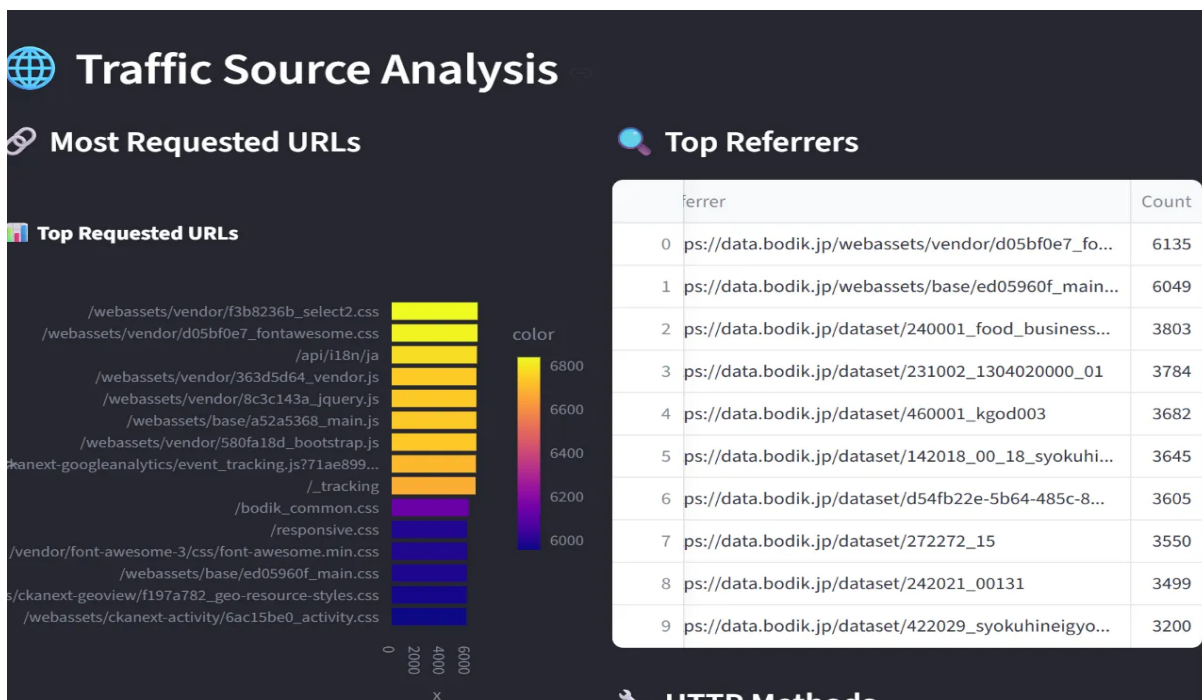


2.この分析の主な目的は、ウェブサーバーの動作を監視・評価し、潜在的な問題を検出することです。

- どのファイルやパスが最も負荷を受けているかを把握する（リソースの最適化やキャッシュ利用に役立つ）
- ユーザーがどの参照元から最も訪問しているかを把握する（マーケティング、SEO、トラフィック管理に活用）。
- サーバーのリソース消費やネットワーク負荷を最適化し、ユーザー行動をより深く理解する。

ステータスコード	意味	回数（割合）	ログに記録される理由
200	成功	166,175 回 (56.7%)	正常にページが表示されたリクエストもすべてログとして記録され、ユーザーの閲覧履歴の把握に利用される
304	未変更 (Not Modified)	105,307 回 (35.9%)	ブラウザのキャッシュが利用された場合でも、アクセス履歴としてログに記録される
302	発見（一時リダイレクト）	11,209 回 (3.82%)	一時的な URL 転送が発生したことを記録し、リダイレクト状況の把握に役立つ
499	クライアント切断	3,584 回 (1.22%)	ユーザーまたはクライアントが途中でリクエストを中断したことを示すため記録される
404	見つかりません	2,330 回 (0.79%)	存在しないページへのアクセスを把握し、リンク切れ確認に利用される
500	サーバー内部エラー	1,797 回 (0.61%)	プログラムや DB などサーバー内部の問題を特定するためログに記録される
403	禁止	1,067 回 (0.36%)	権限のないアクセス試行を記録し、不正アクセス検知に利用される
504	ゲートウェイタイムアウト	580 回 (0.20%)	上位サーバーや API の応答遅延・障害を把握するため記録される
301	恒久的リダイレクト	440 回 (0.15%)	URL 変更履歴を管理し、SEO や転送設定確認に利用される
502	不正なゲートウェイ	231 回 (0.08%)	プロキシやロードバランサーの障害を特定するためログに残る

3. Traffic Source Analysis（トラフィック流入元分析）



本画面は、Web サーバーのアクセスログを基に、どの URL が多くアクセスされているか、どのページ（参照元）からアクセスが発生しているかを可視化した分析結果を示している。

- Most Requested URLs（最もアクセスされた URL）

左側のグラフは、アクセス数が多い上位 URL を示している。主に以下の特徴が確認できる。CSS、JavaScript、フォントファイルなどの静的リソース（/webassets/ 配下）へのアクセスが多い jquery.js や bootstrap.js など、Web ページ表示に必要なライブラリへのリクエストが集中しているカラーバーはアクセス数の多さを表しており、黄色に近いほどアクセス数が多いことを示すこれにより、本 Web サイトではページ表示時に多くの静的リソースが読み込まれていることが分かる。

- Top Referrers（主な参照元）

右側の表は、アクセスの参照元（Referer）とその回数を示している。data.bodik.jp ドメイン内のページからのアクセスが大半を占めているデータセットページ（/dataset/～）からの遷移が多く、利用者がデータ閲覧を目的としてサイトを利用していることが分かる。特定のページから数千回単位のアクセスが発生しており、人気コンテンツや頻繁に参照されるページの把握が可能である。

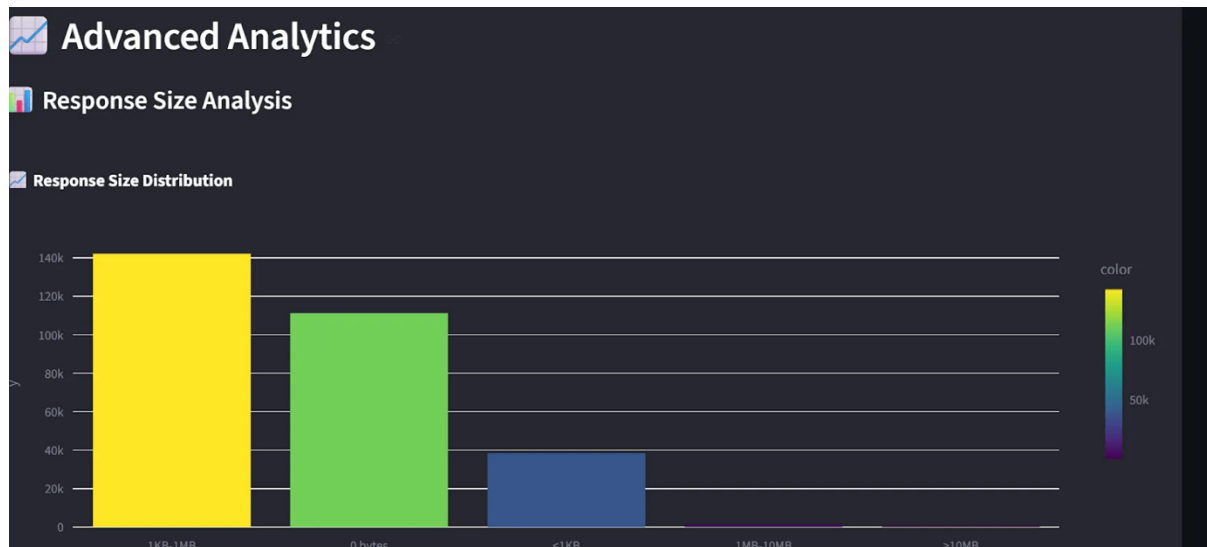
- 分析結果から得られる知見本分析により、以下の点が明らかになった。

Web ページの表示に必要な静的リソースへのアクセスが非常に多い内部ページ（データセットページ）からの遷移が中心であり、外部サイトからの不審な流入は少ない人気ページや高頻度アクセス URL を把握することで、キャッシュ設定やアクセス制御の最適化に活用できる

- セキュリティおよび運用面での活用

本分析結果は、以下の目的に活用できる。アクセス集中箇所の把握によるサーバー負荷対策不要または異常なリクエストの検出

4. Advanced Analytics



目的: この分析は、ウェブサイト管理者が以下を理解するのに役立ちます。

システム負荷の種類: サーバーから配信されるファイルのサイズを把握する。例えば、1MB 以上のファイルが多く配信されている場合、サーバーリソースが多く消費されていることを示します。Website speed の改善: 1KB~1MB のカテゴリーが極端に多い場合、ページの読み込み速度が低下する可能性があります。この場合、画像サイズの縮小や CSS・JS ファイルの統合など、最適化の措置を講じる必要があります。Cache の effectiveness: 0 バイトのレスポンス数が多い場合、キャッシュが適切に機能しており、サーバーへの不要な負荷を防いでいることを示します。サーバーログを自動的に解析し、グラフによる可視化を行うことで、疑わしい IP アドレスや高負荷の原因を迅速に特定できるシステムである。本システムを活用することで、管理者の作業時間を削減するとともに、Web サーバーのセキュリティ向上に貢献することが期待される。

➤ Web アプリケーションの構築

テスト用の Web サイトを作成して、攻撃から守り方の基本を学びました。

これにより、単なる理論的な学習に留まらず、実際の動作環境に近い形でセキュリティ上の課題を検証できる環境を整えた。

Web サーバーで代表的な攻撃手法

- SQL インジェクション (SQL Injection)

Web サイトの入力フォームなどに悪意のある SQL 文を入力し、データベースを不正に操作したり、内部情報を取得したりする攻撃です。入力値の検証不足が主な原因となります。

- クロスサイトスクリプティング (Cross-Site Scripting : XSS)

悪意のあるスクリプトを Web ページに埋め込み、他の利用者のブラウザ上で不正なコードを実行させることで、クッキー情報や個人情報を盗み取る攻撃です。

- クロスサイトリクエストフォージェリ (CSRF)

ユーザーが意図しないリクエストを、ログイン中の状態を利用して Web アプリケーションに送信させる攻撃です。ユーザー本人の操作であるかの確認が不十分な場合に発生します。

- 認証の破損 (Broken Authentication)

弱いパスワードの使用や、不適切なセッション管理によって発生する脆弱性です。不正ログインやなりすましの原因となります。

- 機密データの漏えい (Sensitive Data Exposure)

HTTPS が使用されていない、あるいはデータが暗号化されていない場合に、通信内容や個人情報が第三者に漏えいする危険性があります。

- Web ページへの攻撃テストを実施するために、自身でこのような Web ページを作成してみました。

Golden Fork

私たちについて | メニュー | 予約 | ギャラリー | お問い合わせ | [今すぐ予約](#)

テーブルを予約

特別な日を計画しましょう

オンラインで簡単に予約できます。ご希望の日時と人数を入力してください。

お名前	メールアドレス
日付	時間
mm/yy/yyyy	--:--:--
人数	電話番号
人数を選択	

営業時間

- ランチ 11:30 - 14:00 (月~金)
- ディナー 17:30 - 22:00 (土日)
- 定休日 毎週末曜日

Golden Fork

私たちについて | メニュー | 予約 | ギャラリー | お問い合わせ | [今すぐ予約](#)

完璧な料理への情熱

Golden Forkは、美食への情熱から生まれました。私たちは、世界中から厳選された最高級の食材を使用し、経験豊富なシェフたちが伝統と革新を融合させた料理を作り上げています。お客様一人ひとりに心に残る食事の時間を提供することが私たちの使命です。

- 新鮮な地元食材**
地元の農家と提携提携し、季節ごとの新鮮な食材を使用しています。
- 厳選されたワインリスト**
世界各国のワインを豊富に取り揃え、料理との完璧なペアリングをご提案します。
- 忘れられないダイニング体験**



Golden Fork Restaurant

私たちについて | メニュー | 予約 | ギャラリー | お問い合わせ | [今すぐ予約](#)



Golden Fork

最高の食材と技術が調和して、忘れられないダイニング体験をお約束します。豪華な雰囲気の中で、靈感を満ちた料理をお楽しみください。

[今すぐテーブルを予約](#) | [メニューを見る](#)

25+ | 150+ | 1000+

しかし、準備や開発に時間がかかるため、Web セキュリティを学ぶための脆弱な Web サイト DVWA を用いて実験しました

➤ DVWA (Damn Vulnerable Web Application)

DVWA を用いた Web セキュリティ学習

本来であれば、Web セキュリティを学ぶためにゼロから脆弱性を含む Web アプリケーションを設計・開発することが望ましいですが、準備や実装に多くの時間を要するという課題がありました。そこで本インターンシップでは、Web セキュリティの学習および攻撃手法の理解を効率的に進めるため、意図的に脆弱性が組み込まれている学習用 Web アプリケーションである DVWA (Damn Vulnerable Web Application) を用いて実験を行いました。



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerability** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

DVWA also includes a Web Application Firewall (WAF), PHPIDS, which can be enabled at any stage to further increase the difficulty. This will demonstrate how adding another layer of security may block certain malicious actions. Note, there are also various public methods at bypassing these protections (so this can be seen as an extension for more advanced users)!

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can downloading and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

More Training Resources

DVWA aims to cover the most commonly seen vulnerabilities found in today's web applications. However there are plenty of other issues with web applications. Should you wish to explore any additional attack vectors, or want more difficult challenges, you may wish to look into the following other projects:

■ 実現1：SQL インジェクション (SQL Injection)

1. SQL インジェクションの仕組み

Web applications がユーザーの入力を検証せずに SQL クエリに直接組み込むと、攻撃者は自分の SQL コードを入力として送り、データベースに影響を与えることができます。SELECT * FROM users WHERE username = 'ユーザー入力' AND password = 'パスワード入力';ユーザー入力を検証せずにそのままクエリに埋め込むと、攻撃者は以下のように入力できます：

username: ' OR '1'='1

password: ' OR '1'='1

→ '1'='1' が常に真になるため、認証をバイパスできます。

DVWA

Vulnerability: SQL Injection

User ID:

ID: ' OR '1'='1
First name: admin
Surname: admin

ID: ' OR '1'='1
First name: Gordon
Surname: Brown

ID: ' OR '1'='1
First name: Hack
Surname: Me

ID: ' OR '1'='1
First name: Pablo
Surname: Picasso

ID: ' OR '1'='1
First name: Bob
Surname: Smith

More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_Injection
- <http://bobby-tables.com/>

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

DVWA Security
PHP Info
About

Logout

Username: admin
Security Level: low

■ 実現2 ブルートフォース (Brute Force)

ブルートフォース (Brute Force) 攻撃は、パスワードや暗号鍵などの秘密情報を「片っ端から試す」ことで突破する攻撃手法です。

A. ブルートフォース攻撃の仕組み

攻撃者がターゲット (ログイン画面や暗号化されたデータ) を決める

可能なパスワードや鍵の組み合わせを順番に試す

正しい組み合わせが見つかるまで繰り返す

ユーザー名: admin

パスワード: 0000, 0001, 0002, ... 9999

4桁の数字パスワードなら、最大 10,000 通りを試せば必ず突破可能です。



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

Vulnerability: Brute Force

Login

Username:

Password:

Login

Welcome to the password protected area admin



More Information

- [https://www.owasp.org/index.php/Testing_for_Brute_Force_\(OWASP-AT-004\)](https://www.owasp.org/index.php/Testing_for_Brute_Force_(OWASP-AT-004))
- <http://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password>
- <http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html>

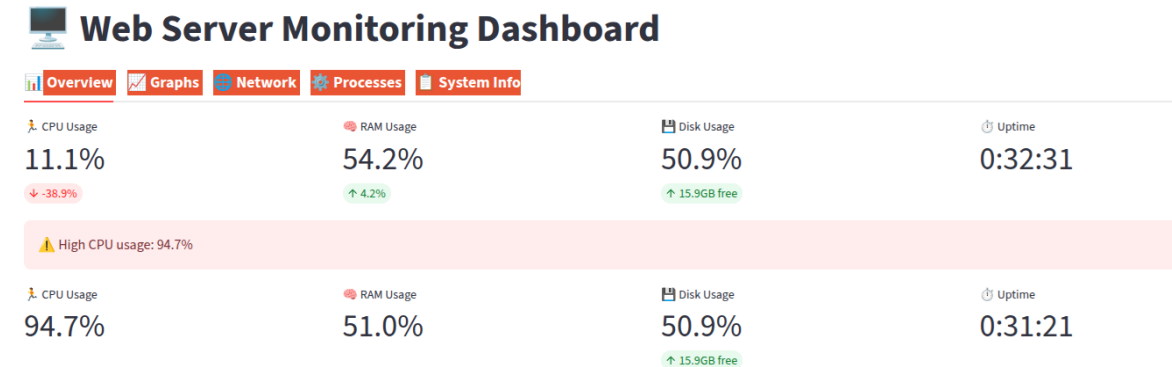
Username: admin
Security Level: low

View Source

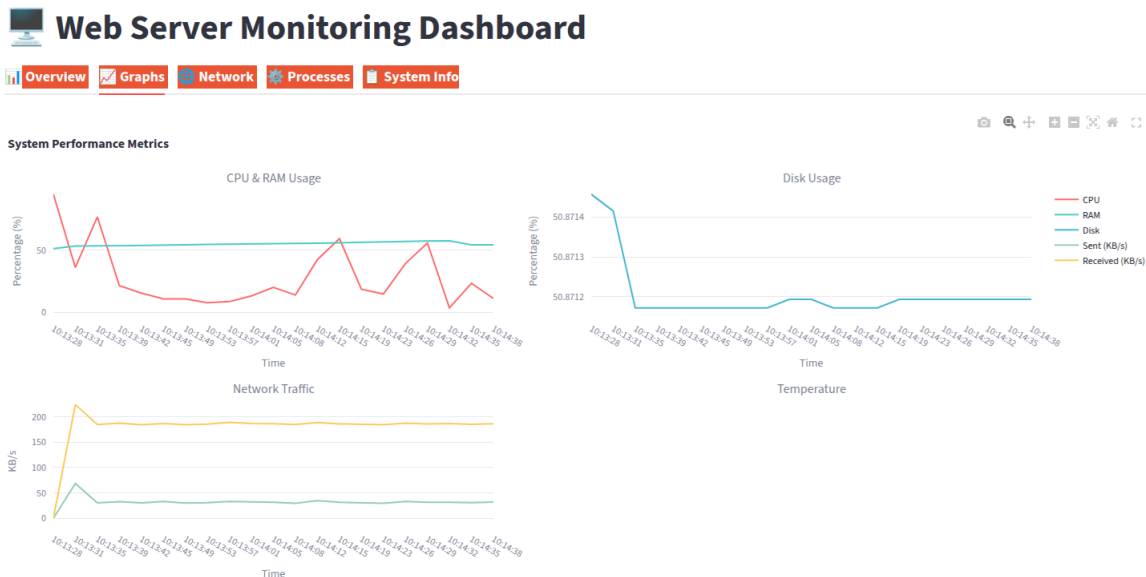
View Help

➤ Web_Server_Dashboard のプログラムの画面

生成した理由：サーバやシステムの状態を一箇所から総合的に監視 する必要があった
CPU、ネットワーク、プロセス、システム情報を 個別に確認するのは手間がかかり、
時間も浪費する負荷や不審なネットワーク動作、異常なプロセスを早期に検知するため
アプリの説明：システム全体の状態を一目で把握できる（CPU、メモリ、ディスク、ネットワークの概要を表示）



- CPU、RAM、ディスク使用率を リアルタイムグラフ で可視化
時系列で負荷の変化を分析可能



Network

- ネットワーク使用状況、送受信トラフィック、アクティブな IP を監視
- 急激なトラフィック増加や不審な接続を検知

 Web Server Monitoring Dashboard

 Overview  Graphs  Network  Processes  System Info

 Website Monitoring

 <https://google.com>

 <https://github.com>

Response Time

256ms

Response Time

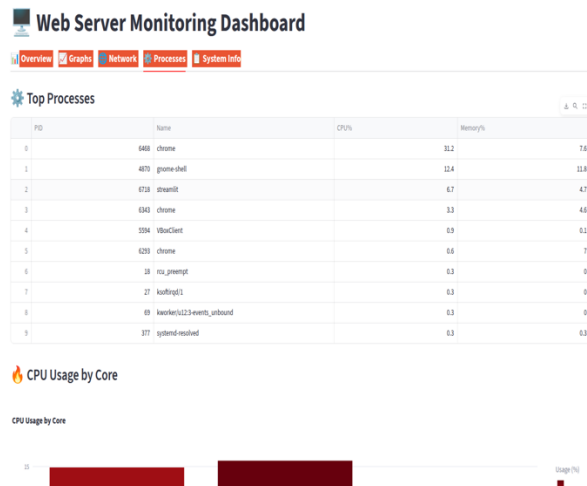
262ms

 Network Interfaces

	Interface	Status	Speed
0	lo	Up	Unknown
1	enp0s3	Up	Unknown
2	docker0	Down	Unknown
3	br-1303a0bf3d7f	Up	10000 Mbps
4	vethc434832	Up	10000 Mbps
5	veth2dadf18	Up	10000 Mbps

Processes

- 稼働中のすべてのプロセスを一覧表示
- CPU やメモリを過剰に使用しているプロセスを特定し、必要に応じて終了可能



簡単な例え

小さな店（＝サーバー）に 10 人のお客さんが入っても問題はない。

しかし、一度に 1000 人が無理やり入ろうとすると、店のスペースが足りず、店員は全員に対応できなくなる。その結果、本来の利用者（＝正規のユーザー）はサービスを受けられなくなってしまいます。

メリット

- 統合監視 – すべての情報を 1 つのダッシュボードで確認可能
- リアルタイム情報 – 負荷の変化を即座に把握できる
- セキュリティ強化 – 不審なネットワーク接続や異常プロセスを早期検出
- 使いやすい UI – 管理者や利用者にとって直感的でわかりやすい
- 拡張性 – 他のサーバやサービスも追加して監視可能

➤ インターンシップで学んだこと

- 専門的なスキル（レポート用）

本演習を通じて、ウェブ開発、サーバー監視、プログラミング、WBS およびデータベースの基礎に関する知識を体系的に学習した。特に、Web アプリケーションの構成やサーバーの動作原理を理解した。また、DVWA（Damn Vulnerable Web Application）を用いた攻撃テストを実施し、SQL インジェクションや XSS などの代表的な脆弱性について、攻撃者視点と防御者視点の両面から理解を深めた。加えて、サーバーログの確認・分析を行うことで、不審な挙動や攻撃の痕跡を把握する実践的な経験を積んだ。さらに、演習中に問題が発生した際には、エラーメッセージやログ情報を手がかりに原因を調査し、ドキュメントや技術情報を参照しながら自ら解決する能力を養った。これにより、単に指示された作業を行うだけでなく、実運用を想定したトラブルシューティング能力や主体的に課題へ取り組む姿勢を身につけることができた。

- ソフトスキル（個人の視点で学んだこと）

本演習を通じて、業務を円滑に進めるためのソフトスキルの重要性を実感した。特に、ハウレンソウ（報告・連絡・相談）を意識して行動することで、状況共有の遅れによる問題を防ぎ、周囲と協力しながら作業を進める習慣が身についた。

また、分かりやすく簡潔に伝える力が向上した。専門的な内容であっても、要点を整理し、相手に伝わりやすい形で説明することを心がけることで、コミュニケーションの質を高めることができた。

さらに、期限内にタスクをやり遂げる意識が向上した。任された作業に対して責任を持ち、作業内容を計画的に整理しながら進めることで、納期を意識した行動が取れるようになった。

加えて、課題に直面した際の改善提案力も向上した。問題が発生した場合には、自ら調査を行い、原因を分析した上で解決策を検討し、改善案として提案する姿勢を身につけることができた。

まとめ

今回のインターンシップでは、Traffic Eye を用いたログ分析、Web アプリケーションの構築、DVWA を用いた脆弱性攻撃の体験という三つの活動を通して、セキュリティ運用に関する理解を深めることができた。実際の運用を想定した環境で学習することで、ログから異常を読み取る重要性や、Web アプリケーションに潜む脆弱性の危険性を実感した。

また、攻撃者の視点と防御側の視点の両方を体験することで、セキュリティ対策は単なる技術導入だけでなく、継続的な監視や適切な運用が不可欠であることを理解した。本インターンシップを通じて、安全なアプリケーション開発とセキュリティ運用に必要な基礎的知識と実践力を身につけることができた。